ICare After-Fix Security Assessment

Optical Store Management System | SE4030 Secure Software Development | Group 113

Assessment date: 16 October 2026 (Asia/Colombo). Execution timestamps are preserved in UTC in the evidence bundle.

Special focus: Baskaran V - IT22172600 | V03, V04 and V05

Independent verification, with limitations

Actual isolated HTTP/database tests and OWASP ZAP passive scanning. No unrestricted active scan. No claim that all vulnerabilities are fixed.

This is an independently authored assessment. The companion ZAP HTML/PDF contains scanner-exported results; manual regression findings remain separately labelled.

1. Executive summary

Executed 52 targeted cases: 47 PASS and 5 FAIL. Existing backend regression: 15 passed. Targeted Payments UI regression: 7 passed. No production or shared development database was used.

Core owner/admin restrictions and server-side order pricing behaved correctly in tested scenarios. Card storage functionality is removed. Remaining verified concerns include security headers/SRI, acceptance of legacy reset-shaped JWTs, and route-local prescription validation detail disclosure. These are not silently remediated during this assessment.

Comparison status	Count
NOT VERIFIED	3
FIXED	5
NOT APPLICABLE	1
PARTIALLY FIXED	3

FIXED means the equivalent attack documented in the supplied before-fix evidence failed safely during this assessment. The baseline itself was not rerun. Where baseline exploitation evidence is absent, NOT VERIFIED is used despite passing after-fix checks. These results apply only to the covered cases and dirty source snapshot.

2. Objectives, scope and safety

Verify V01-V12 plus all extra findings from the supplied ZAP baseline. Target: isolated hardened Express backend serving the current compiled React build, not the running shared development applications on ports 3000/3001/4000/4001.

A new disposable MongoDB container uses localhost port 27028 and tmpfs /data/db. Initial collection count was zero before synthetic users/products/orders/prescription/ticket creation. A dedicated Node process runs on port 4021 without loading the existing .env: its working directory is an empty assessment runtime folder, and the child receives a restricted environment. Mailgun, payment, Google OAuth and Cloudinary settings are empty. No valid external upload, payment provider or OAuth flow was attempted.

ZAP accesses only host.docker.internal:4021, the Docker Desktop alias for this local host backend. Proxy/API is published only on 127.0.0.1:8091. No spider, active scanner, external domain, destructive baseline seed route, real card or real reset email was used. Successful writes were restricted to new synthetic fixtures.

3. Tools, versions and source identity

Component	Recorded value
Node.js	v24.14.0
OWASP ZAP	2.17.0 (actual API version)
Docker Engine	29.3.0
MongoDB	See docker-environment.json for actual image/server version
Environment	{"database": "icare_afterfix_1e4ac2f3a353", "mongo": "127.0.0.1:27028", "backend": "127.0.0.1:4021", "zapTarget": "http://host.docker.internal:4021", "zapProxy": "127.0.0.1:8091", "initialCollections": 0, "syntheticOnly": true, "externalIntegrations": "disabled; no valid external-provider requests attempted", "counts": {"users": 3, "orders": 6, "products": 1, "prescriptions": 1, "tickets": 1}, "assessmentTime": "2026-10-16T11:07:04.017Z"}
Baseline source	5b5b25869d92a662b1e5180eb1b4f22bcf3a7830
Security hardening commit	0b57ca91c60576b4309d72108839591d32370b50
Current HEAD	d7e93299cde0a19bf9aa495fbc592d2fec13b938
Working tree	Dirty: previously implemented Payments UI/test changes plus pre-existing .env.example modification. SHA-256 source manifest identifies actual evaluated files.

The supplied ZAP baseline names ZAP 2.17.0 and target http://127.0.0.1:4010, generated 16 October 2026 15:39:47 (timezone unspecified). It does not identify a Git commit SHA. Consequently its source identity cannot be cryptographically bound to the available original baseline commit. It is treated as supplied historical evidence, not a baseline rerun by this assessment.

No production source or dependencies were changed during this assessment. Earlier authorized UI/test changes remain in the working tree. New assessment scripts, logs, CSV and reports are under output/ and temporary PDF libraries/renderings under tmp/. Existing .env files were not overwritten.

Assessment-owned MongoDB and ZAP containers, ephemeral databases and anonymous container volumes were removed after sanitized evidence export. Assessment ports 4021, 8091 and 27028 were confirmed closed. Downloaded images remain cached. See cleanup.json; shared applications/databases were not stopped or modified.

4. Methodology and evidence strength

Source review and source hashes; existing mocked/unit tests; independent full HTTP tests through the actual ZAP proxy against disposable MongoDB; before/after database snapshots for denied mutations; passive scan alert export after queue drain. Exceptions and passwords/tokens are sanitized in distributed evidence. ZAP-native History remains ephemeral and is not exported as a raw session containing bearer tokens.

Evidence files: isolation.json, docker-environment.json, manifest.json, test-results.json, http-exchanges.json, zap-history-index.json, zap-alerts.json, zap-version.json, backend-regression.txt and frontend-regression.txt. The harness verify.mjs is executable and refuses a nonempty test database. A fresh approved temporary database/container is required for replay.

5. ZAP passive alert summary

Risk	Before types	After types
High	11	0
Medium	5	3
Low	4	3
Informational	1	1

Before totals mix 13 manually entered verified findings with 8 automatic passive alert types (21 types total). After totals above are only automatically generated passive alert types. Counts are not directly equivalent; manual vulnerabilities are evaluated in the separate verification matrix. Zero alerts of a risk is not proof of absence.

Plugin	Risk / alert	Instances
10021	Low / X-Content-Type-Options Header Missing	17
90022	Low / Application Error Disclosure	2
10020	Medium / Missing Anti-clickjacking Header	3
10038	Medium / Content Security Policy (CSP) Header Not Set	3
10109	Informational / Modern Web Application	3
90003	Medium / Sub Resource Integrity Attribute Missing	3
10023	Low / Information Disclosure - Debug Error Messages	1

The companion ICare_ZAP_After_Fix_Report.html and PDF are actual target-filtered ZAP native exports (traditional-html and traditional-pdf templates). No manual findings were inserted into the after-fix ZAP alert list. Token/credential leakage checks were performed before delivery.

Triage: new passive plugin 10023 flags the generic text "Internal server error" on the malformed-JSON case. That response contains no verified debug details, so this instance is an unconfirmed/likely false-positive disclosure alert; its HTTP 500 classification should still become 400. Plugin 90022 includes the genuinely detailed prescription validation response as well as generic error wording. Scanner alert counts are observations, not counts of confirmed exploits.

Scanner setup initially used the mapped API port as a normal origin and produced connection errors; switching to the reserved http://zap API host resolved it before target testing. Native report Insights can include those global setup warnings/network statistics even with site filtering. All 53 recorded target exchanges completed and are individually mapped to History IDs; the 11 additional status-0 History entries are site-tree placeholders, not sent test requests. No target failure is inferred from global setup statistics.

6. V01-V12 verification matrix

ID / finding	Status	Evidence and qualification
V01 Public seed reset	NOT VERIFIED	Hardened GET 404 and counts unchanged. Baseline source demonstrates destructive route, but supplied ZAP report explicitly excluded /api/seed; no baseline exploit replay.
V02 Order IDOR	FIXED	Owner/admin 200; unrelated customer 404. Equivalent supplied baseline VIVA-01 disclosure blocked.
V03 Payment/delivery authorization	FIXED	401/403 negative controls; canonical admin COD 200 persisted; paid/non-COD/Demo 400; missing 404; rejected documents unchanged. Matches VIVA-02/03/04.
V04 Client-controlled prices	FIXED	Client 0.01 ignored; database catalog 200 x 2 gives 460. Quantity/stock/duplicate/invalid products rejected; shipping boundary tested. Supplied VIVA-05 equivalent blocked.
V05 Card storage and CVV	NOT APPLICABLE	Active feature removed: GET/POST card API 404, no card route/model, synthetic order strips card-shaped fields. Historical database/backups cleanup NOT VERIFIED.
V06 Prescription access	FIXED	Customer list/detail/create/edit 403; document unchanged; admin read 200. Blocks supplied VIVA-06/07.
V07 Stale administrator token	NOT VERIFIED	After-fix demotion 403 and deletion 401 verified. Baseline source/mocked regression only; supplied ZAP baseline has no reproduced stale-role finding.
V08 Sensitive user responses	NOT VERIFIED	Current list/detail/update omit password/reset/google identifiers. Baseline source only; no equivalent reproduced baseline response supplied.
V09 Password-reset security	PARTIALLY FIXED	Opaque expired/reused tokens rejected, current opaque token not access bearer. Legacy reset-shaped JWT signed with same secret still accepted as access token. Issuance/logging path with actual mail intentionally not tested.
V10 Upload validation	PARTIALLY FIXED	Spoofed/disallowed files 400; >5 MB 413; allowed signatures unit-checked. No full image decode, external upload or baseline upload exploit replay.
V11 Ticket authorization	FIXED	Other customer response 404 with unchanged ticket; owner 201. Supplied VIVA-08 equivalent blocked.
V12 Internal errors	PARTIALLY FIXED	Malformed order ID now generic 400, global parse/internal error generic 500. Prescription route-local validation catch still exposes Mongoose details.

7. Supplied baseline manual findings mapped

All rows below are historical claims from the supplied before-fix PDF, not tests newly executed against the vulnerable baseline. Manual findings have no automatic scanner plugin ID. Their History markers are reproduced as document references; the original native ZAP session was not supplied.

Baseline / risk	Endpoint / History	Mapping / original evidence
VIVA-01 / High / Order disclosure	GET /api/orders/{id} / viva-0005	V02 / Alice read Bob order; anonymous control 401.
VIVA-02 / High / Unauthorized delivery	PUT /api/orders/{id}/deliver / viva-0006	V03 / Non-admin changed Bob isDelivered false to true.
VIVA-03 / High / Unverified provider payment	PUT /api/orders/{id}/pay / viva-0009	V03 / Empty JSON marked an unpaid PayPal order paid.
VIVA-04 / High / Cross-user payment	PUT /api/orders/{id}/pay / viva-0010	V03 / Alice marked Bob separate order paid.
VIVA-05 / High / Price tampering	POST /api/orders / viva-0011	V04 / Catalog 100 accepted client price/total 0.01.
VIVA-06 / High / Prescription disclosure	GET /api/prescriptions/{id} / viva-0012	V06 / Unrelated customer read synthetic prescription.
VIVA-07 / High / Prescription modification	PUT /api/prescriptions/{id} / viva-0013	V06 / Unrelated customer modified prescription.
VIVA-08 / Medium / Ticket response injection	POST /api/tickets/{id}/responses / viva-0015	V11 / Other customer appended response (201); read control 404.
VIVA-09 / High / PAN/CVV persisted and returned	GET /api/card-details / viva-0018	V05 / Full synthetic card fields returned by later GET.
VIVA-10 / High / Reset token reuse	POST /api/users/reset-password / viva-0020	V09 / Same fixture reset token changed password twice.
VIVA-11 / High / Reset JWT as access token	GET /api/card-details / viva-0022	V09 / token purpose / Reset-shaped fixture JWT accepted as bearer.
VIVA-12 / Medium / Single-character password	POST /api/users/signup / viva-0023	Additional / One-character password accepted, session token issued.
VIVA-13 / Low / Internal error details	GET /api/orders/not-a-valid-object-id / viva-0024	V12 / HTTP 500 exposed ObjectId cast implementation details.

8. Supplied baseline passive findings mapped

Plugin / risk / name	Original location / mapping	After-fix outcome
10062 / High / PII Disclosure	GET/POST /api/card-details; 2 instances / V05	Card endpoints removed, 404; active feature NOT APPLICABLE. Historical records not assessed.
10038 / Medium / CSP Header Not Set	/, /signin, /signup; systemic / Additional	NOT FIXED: missing controls independently observed on hardened HTML. See after-fix alerts for scanner coverage.
10020 / Medium / Missing Anti-clickjacking Header	/, /signin, /signup; systemic / Additional	NOT FIXED: missing controls independently observed on hardened HTML. See after-fix alerts for scanner coverage.
90003 / Medium / SRI Attribute Missing	External Font Awesome stylesheet; systemic / Additional	NOT FIXED: missing controls independently observed on hardened HTML. See after-fix alerts for scanner coverage.
90022 / Low / Application Error Disclosure	Malformed order identifier; 1 instance / V12	Original malformed-ID case fixed (400 generic); broader V12 PARTIALLY FIXED due route-local disclosure.
10037 / Low / X-Powered-By disclosure	Express header; systemic / Additional	FIXED for tested Express responses: X-Powered-By absent, matching app.disable. Other deployments not assessed.
10021 / Low / X-Content-Type-Options Missing	HTML pages; systemic / Additional	NOT FIXED: missing controls independently observed on hardened HTML. See after-fix alerts for scanner coverage.
10109 / Informational / Modern Web Application	React script shell; systemic / Informational	NOT APPLICABLE as vulnerability; informational SPA classification.

Additional VIVA-12 weak password finding: single-character registration now returns 400 with no new account. Server enforces at least 12 characters. This does not establish breached-password screening, rate limiting or a complete password policy.

Additional VIVA-11 token confusion is not fully dismissed merely because the card route was removed. A reset-shaped shared-secret JWT was tested against an active /api/orders/mine endpoint and remained accepted. New opaque reset tokens returned 401 as access bearers.

The reset-shaped JWT was generated only for the isolated test using its ephemeral signing key. This is a token-validation/legacy-compatibility check, not proof that a customer can forge a signed JWT or that the current opaque reset flow issues access-compatible tokens. Exploitation by an actual historical reset token depends on unchanged signing secrets and token validity.

9. Baskaran V: detailed V03 analysis

Original evidence: VIVA-02/viva-0006 unauthorized delivery; VIVA-03/viva-0009 empty JSON provider payment; VIVA-04/viva-0010 cross-user payment. Current routes/orderRoutes.js:133-153 applies isAuth then isAdmin; line 140 rejects a method other than exact Cash On Delivery or already paid. utils.js:26-49 reloads the current account/role before authorization.

Normal customer request: valid access token -> current user found -> isAdmin fails -> 403 -> unchanged order. Anonymous request -> 401. Administrator confirms cash collection -> unpaid canonical COD -> paid flag, paidAt and paymentResult.status persisted -> 200 with updated order. Backend trusts staff acknowledgement of physical cash; it does not verify an online payment gateway.

Canonical COD positive case was performed only on a new synthetic order. Unsupported PayPal and Demo - Cash on Delivery fixtures returned 400, already-paid returned 400, missing returned 404. Rejected orders were compared as full lean documents before/after. The previously reported shared demo order was neither read nor changed in this assessment.

Admin UI source has cash-collected confirmation, processing disable and response-based state refresh; targeted mocked frontend tests passed. No browser session was used to confirm a real payment. Existing demo migration remains separate and unexecuted. No concurrent double-confirmation or staff audit-trail test was performed; find-then-save is not an atomic payment transition.

Selected actual request/response evidence

anonymous pay: {"status": "PASS", "http": 401, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}}

customer pay: {"status": "PASS", "http": 403, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}}

customer delivery: {"status": "PASS", "http": 403, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}}

admin confirms canonical COD: {"status": "PASS", "http": 200, "before": {"isPaid": false}, "after": {"isPaid": true, "paidAt": "2026-10-16T11:06:55.820Z", "paymentResult": {"status": "Paid"}}}

already paid: {"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "unchanged": true}

non-COD: {"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "unchanged": true}

Demo label mismatch: {"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "unchanged": true}

missing order: {"status": "PASS", "http": 404}

admin delivery: {"status": "PASS", "http": 200}

10. Baskaran V: detailed V04 analysis

Original VIVA-05/viva-0011 accepted catalog 100 at submitted total 0.01. Current order creation loads Product records then calls priceOrder (backend/orderPricing.js:1-17), which copies catalog fields, validates integer quantity 1-100 and current stock, rejects duplicate/unknown products and recalculates items, shipping, 15% tax and rounded total.

Independent saved-order test submitted price/total 0.01 against catalog price 200 and quantity 2: persisted items=400, tax=60, shipping=0, total=460. Boundary fixture catalog=100 and quantity=1 persisted shipping=10 and total=125. Excess stock, fractional/zero quantity, duplicates, unknown/invalid products were rejected without new orders.

Limit: stock is checked but not reserved/decremented atomically during order creation. Concurrent overselling and pricing races were not tested. A successful pricing integrity test is not a stock concurrency guarantee.

11. Baskaran V: detailed V05 analysis

Original VIVA-09/viva-0018 and passive plugin 10062 documented full synthetic PAN/CVV persistence and API disclosure. Current source has no active card model/route/form. GET and POST /api/card-details both returned 404. A new order containing harmless non-card strings in card-shaped fields persisted/returned none of cardDetails, cardNumber or cvv.

Current model has payment metadata and isPaid/paidAt, not PAN/CVV fields. Checkout is COD only. This verifies removal of the active feature, not erasure of historical database documents/backups. Existing/shared databases were deliberately not inspected, migrated or purged. Hosted gateway integration remains outside scope.

12. Complete executed case results

Case / ID	Test / expected	Actual / status
1 / V01	seed route removed | 404; database counts unchanged	{"status": "PASS", "http": 404, "before": [4, 1], "after": [4, 1], "pass": true}
2 / V02	owner reads owner order | 200	{"status": "PASS", "http": 200, "pass": true}
3 / V02	other reads owner order | 404	{"status": "PASS", "http": 404, "pass": true}
4 / V02	admin reads owner order | 200	{"status": "PASS", "http": 200, "pass": true}
5 / V03	anonymous pay | 401; record unchanged	{"status": "PASS", "http": 401, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}, "pass": true}
6 / V03	customer pay | 403; record unchanged	{"status": "PASS", "http": 403, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}, "pass": true}
7 / V03	customer delivery | 403; record unchanged	{"status": "PASS", "http": 403, "before": {"isPaid": false, "isDelivered": false}, "after": {"isPaid": false, "isDelivered": false}, "pass": true}
8 / V03	admin confirms canonical COD | 200; persisted paid timestamp/status	{"status": "PASS", "http": 200, "before": {"isPaid": false}, "after": {"isPaid": true, "paidAt": "2026-10-16T11:06:55.820Z", "paymentResult": {"status": "Paid"}}, "pass": true}
9 / V03	already paid | 400; no mutation	{"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "paymentMethod": "Cash On Delivery", "unchanged": true, "pass": true}
10 / V03	non-COD | 400; no mutation	{"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "paymentMethod": "PayPal", "unchanged": true, "pass": true}
11 / V03	Demo label mismatch | 400; no mutation	{"status": "PASS", "http": 400, "message": "Order cannot be marked paid", "paymentMethod": "Demo - Cash on Delivery", "unchanged": true, "pass": true}
12 / V03	missing order | 404	{"status": "PASS", "http": 404, "pass": true}
13 / V03	admin delivery | 200; delivered stored	{"status": "PASS", "http": 200, "pass": true}
14 / V04	catalog price defeats tampering | 201; items=400 tax=60 shipping=0 total=460	{"status": "PASS", "http": 201, "after": {"price": 200, "items": 400, "tax": 60, "shipping": 0, "total": 460}, "pass": true}
15 / V04	excess stock | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
16 / V04	fractional quantity | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
17 / V04	zero quantity | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
18 / V04	duplicate | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
19 / V04	unknown product | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
20 / V04	invalid product | 400; no order created	{"status": "PASS", "http": 400, "before": 4, "after": 4, "pass": true}
21 / V04	shipping threshold arithmetic | 201; items=100 tax=15 shipping=10 total=125	{"status": "PASS", "http": 201, "after": {"items": 100, "tax": 15, "shipping": 10, "total": 125}, "pass": true}
22 / V05	removed card API GET | 404	{"status": "PASS", "http": 404, "pass": true}
23 / V05	removed card API POST | 404	{"status": "PASS", "http": 404, "pass": true}

Case / ID	Test / expected	Actual / status
24 / V05	synthetic order ignores card-shaped fields | 201; no card fields stored/returned	{"status": "PASS", "http": 201, "pass": true}
25 / V06	customer list | 403; prescription unchanged	{"status": "PASS", "http": 403, "unchanged": true, "pass": true}
26 / V06	customer detail | 403; prescription unchanged	{"status": "PASS", "http": 403, "unchanged": true, "pass": true}
27 / V06	customer edit | 403; prescription unchanged	{"status": "PASS", "http": 403, "unchanged": true, "pass": true}
28 / V06	customer create | 403; prescription unchanged	{"status": "PASS", "http": 403, "unchanged": true, "pass": true}
29 / V06	admin prescription read | 200	{"status": "PASS", "http": 200, "pass": true}
30 / V07	demoted administrator old token | 403 after database demotion	{"status": "PASS", "http": 403, "pass": true}
31 / V07	deleted account old token | 401	{"status": "PASS", "http": 401, "pass": true}
32 / V08	admin list | 200; sensitive keys absent	{"status": "PASS", "http": 200, "pass": true}
33 / V08	admin detail | 200; sensitive keys absent	{"status": "PASS", "http": 200, "pass": true}
34 / V08	admin update | 200; sensitive keys absent	{"status": "PASS", "http": 200, "pass": true}
35 / V09	expired token | 400; password unchanged	{"status": "PASS", "http": 400, "pass": true}
36 / V09	single-use reset token | 200 then 400; cleared hash/expiry; no token in logs	{"status": "PASS", "http": [200, 400], "tokenLogged": false, "pass": true}
37 / V09	known/unknown email generic response, mail disabled | same 200 response	{"status": "PASS", "http": [200, 200], "message": "If the account exists, a reset link has been sent.", "pass": true}
38 / V09	opaque reset token rejected as API bearer | 401	{"status": "PASS", "http": 401, "pass": true}
39 / V09	legacy reset-shaped JWT accepted as access token | 401 desired; defense-in-depth check	{"status": "FAIL", "http": 200, "pass": false, "detail": "New reset flow issues opaque tokens, not JWTs. Shared-secret legacy reset-shaped JWTs still satisfy isAuth; no issuer/audience/purpose enforcement."}
40 / V10	MIME spoof | 400; no external upload	{"status": "PASS", "http": 400, "pass": true}
41 / V10	disallowed type | 400; no external upload	{"status": "PASS", "http": 400, "pass": true}
42 / V10	oversized image | 413; no external upload	{"status": "PASS", "http": 413, "pass": true}
43 / V10	allowed JPEG PNG WebP signatures (unit only) | recognized; external upload excluded	{"status": "PASS", "pass": true, "detail": "Signature recognition only; not full image decoding or end-to-end Cloudinary upload."}
44 / V11	other customer cannot respond | 404; responses unchanged	{"status": "PASS", "http": 404, "unchanged": true, "pass": true}
45 / V11	owner can respond | 201	{"status": "PASS", "http": 201, "pass": true}
46 / V12	malformed order identifier | 400 generic; no stack/cast details	{"status": "PASS", "http": 400, "message": "Invalid request", "pass": true}
47 / V12	internal prescription validation error | generic error without implementation details	{"status": "FAIL", "http": 500, "pass": false, "detail": "Route-local catch may expose Mongoose validation details even though global middleware is generic."}
48 / EXTRA-PASSWORD	single-character signup rejected | 400; no account created	{"status": "PASS", "http": 400, "pass": true}

Case / ID	Test / expected	Actual / status
49 / HEADERS	HTML headers and SRI / | security headers and external stylesheet integrity	{"status": "FAIL", "http": 200, "pass": false, "headers": {"csp": null, "xFrameOptions": null, "nosniff": null, "xPoweredBy": null}, "externalStylesheetWithoutIntegrity": true}
50 / HEADERS	HTML headers and SRI /signin | security headers and external stylesheet integrity	{"status": "FAIL", "http": 200, "pass": false, "headers": {"csp": null, "xFrameOptions": null, "nosniff": null, "xPoweredBy": null}, "externalStylesheetWithoutIntegrity": true}
51 / HEADERS	HTML headers and SRI /signup | security headers and external stylesheet integrity	{"status": "FAIL", "http": 200, "pass": false, "headers": {"csp": null, "xFrameOptions": null, "nosniff": null, "xPoweredBy": null}, "externalStylesheetWithoutIntegrity": true}
52 / V12	malformed JSON global internal handler | generic 500 without stack	{"status": "PASS", "http": 500, "message": "Internal server error", "pass": true, "detail": "Generic response verified; malformed JSON should preferably return 400."}

13. Remaining risks and limitations

Verified token-purpose gap: legacy reset-shaped JWT signed with the same secret still authenticates against an active endpoint. Current reset issuance uses opaque hashes, reducing new exposure, but old-token validity depends on credential rotation and remaining token lifetime.

Verified error-detail gap: prescription update has a route-local catch returning error.message, bypassing the safer global handler. Full V12 remediation needs centralized sanitized responses and regression coverage for every local error handler.

Verified missing CSP, anti-clickjacking and nosniff controls, plus external stylesheet without SRI. Treat these independently from business-logic fixes. Deployment/CDN headers may differ from this local backend.

Upload checks recognize short file signatures, not complete image decoding; valid external Cloudinary upload intentionally excluded. Size/type negative tests do not prove safe re-encoding or malware handling.

Source history/working examples may contain credentials; values were not printed or copied into this report. Rotation, secret scanning and historical card/backups cleanup remain operational work requiring separate authorization.

Bearer tokens remain in localStorage, and rate limiting/dependency auditing/full browser coverage were not performed. No real Google OAuth, mail or payment-provider interaction occurred.

Provided baseline scan has no recorded commit SHA or native session; historical claims are attributed to its PDF. V01/V07/V08 lack reproduced baseline exploit evidence, so strict comparison status remains NOT VERIFIED.

Only synthetic fixtures were changed. No production/shared database was connected by the harness. No actual existing demo normalization/migration was run. Do not present this as production penetration-test certification.

14. Recommendations and viva demonstration

Priority 1: address token-purpose validation/legacy-token invalidation and sanitize route-local errors. Priority 2: deploy/test CSP, frame protection, nosniff and stylesheet integrity; improve upload decoding. Priority 3: rotate exposed historical credentials, verify historical-data cleanup, add rate limits, secure session design and concurrency/audit tests. No remediation was made automatically in this assessment.

For the viva, show the source snapshot manifest, isolated database/container mapping, actual sanitized HTTP evidence and ZAP History IDs. Demonstrate a denied customer payment (403) and canonical synthetic admin COD confirmation (200), then price tampering recalculation and removed card API (404). Explain why Demo labels remain separate from stored payment methods. Show at least one remaining finding honestly. Use fresh isolated fixtures; never replay against shared development ports.

Source trace and residual-error excerpt

Area	File and relevant lines
V01/V12	ICare/backend/server.js:61-75 (API fallback/global errors)
V02/V03	ICare/backend/routes/orderRoutes.js:102-153
V04	ICare/backend/routes/orderRoutes.js:23-42; ICare/backend/orderPricing.js:1-17
V05	ICare/backend/models/orderModel.js:34-49; source-review.json
V06/V12	ICare/backend/routes/prescriptionRoutes.js:10-79; raw route-local catch at line 74
V07	ICare/backend/utils.js:26-49
V08/V09/password policy	ICare/backend/routes/userRoutes.js:10-30, 68-114, 174 onward

Area	File and relevant lines
V10	ICare/backend/routes/uploadRoutes.js:8-35
V11	ICare/backend/routes/ticketRoutes.js:123 onward
Admin payment UI	ICare/frontend/src/screens/PaymentListScreen.js:20-29, 91-111, 213-226

Actual isolated response: {"message": "Error updating prescription", "error": "Prescription validation failed: patientName: Cast to string failed for value \"{ synthetic: 'invalid object' }\" (type Object) at path \"patientName\""} | HTTP 500 | exchange 48

15. Conclusion and source references

The evaluated hardened snapshot blocks the tested core business-logic attacks, but the application is not fully secure. This report is suitable as supporting university evidence when submitted with its CSV, sanitized evidence and limitations. It must not be presented as an all-clear ZAP certificate or proof that every V01-V12 issue is fully fixed.

Inputs: optical-store-zap-report.pdf (15 pages; supplied before-fix evidence), SSD_Assignment_GroupID -113.pdf (9 pages; assessment narrative and assigned contributions). Their SHA-256 values are in manifest.json. Source paths in this report are relative to the repository root; line numbers refer to the hashed evaluated snapshot.

Official ZAP installation and version guidance: https://www.zaproxy.org/download/ ; Windows/Linux require Java 17+ or use the official container image. This run used the approved official container, not a newly installed desktop application.